A Minimum Viable Information Risk Management Program

October 2017

Prepared by
Rachael Lininger
Leviathan Security Group Risk and Advisory Services

leviathan security group

©2017 Leviathan Security Group, Inc.

All Rights Reserved.
This document contains information, which is protected by copyright.

.

Disclaimer:
No trademark, copyright, or patent licenses are expressly or implicitly granted (herein) with this analysis, report, or white paper.

All brand names and product names used in this document are trademarks, registered trademarks, or trade names of their respective holders. Leviathan Security Group is not associated with any other vendors or products mentioned in this document.

The Binary Risk Analysis methodology described in this document has been published by Ben Sapiro under the Creative Commons Attribution-Sharealike 3.0 license (CC BY-SA 3.0), available below:
https://creativecommons.org/licenses/by-sa/3.0/

Contents

The Risk Management Problem 4
What is risk? 4
The Basic Plan 6
Decide on scope 6
Inventory assets and owners 6
Sort the inventory by granularity 8
Perform Binary Risk Assessment 8
Asset owners decide treatment for low & medium risks 9
Senior leadership reviews all risks & decides on high 10
Document and review 11
Strengths and weaknesses of Binary Risk Assessment 11
Scaling the Program 12
Document and Review 12
Risk management policy 13
Risk management process 13
Risk assessment templates 13
Risk treatment decision templates 13
Risk register 14
Meeting minutes 14
Review 14
Conclusion 15
References 16

The Risk Management Problem

Risk management is a fundamental requirement for all major information security frameworks, but there is little practical guidance for implementing a risk management program at small or young organizations. Existing risk management practices require varying levels of staff, expertise, tooling, and time — all expensive — as well as a mature concept of risk, when none of these necessities may be available. Consequently, there is an industry-wide need for a "minimum viable program" that allows organizations to manage risk despite lacking the prerequisites for more full-featured risk management programs. This white paper outlines such a program.

Risk management is the process of identifying problems before they occur and responding appropriately to reduce potential losses to an acceptable level. The inability to do this effectively at small scale is the root cause of many intractable problems in information security and arguably one of the unsolved problems of the field.

Compliance is a necessary, but not sufficient, reason to implement a risk management program. While it is possible for an organization to enforce a risk management program solely for compliance reasons, such a program will have little impact and likely be regarded as busywork. In order to fully realize risk management's value, it must be made useful to the organization beyond compliance concerns.

In addition to complying with legislation (such as HIPAA) and industry-wide frameworks (such as the Payment Card Industry Security Standards), risk management can fulfill other business needs. Risk management contributes to improving organizational decision-making and enables long-term planning. Risk management can help an organization determine which processes are best outsourced (for example, payments, if that's not the organization's core competency, are frequently outsourced). Risk management can help frame conversations about early organizational decisions that do not serve organizational strategies (e.g., that stupid thing the cofounder likes). Business customers with a vendor security questionnaire process often ask about risk management, and having a program may reduce sales friction.

Perhaps most importantly, a good risk management program can help identify those who are truly accountable for risks and ensure that decisions about risks are made at the appropriate level. One common failure pattern is that the information security function is considered responsible for risks it identifies, despite lacking the authority to enforce mitigations. Another common pattern is that risks are not identified effectively, resulting in their tacit acceptance. A robust risk management program will correct these issues.

What is risk?

Because risk management is a fundamental requirement, the term "risk" is used for many aspects of security, regardless of its relevance. In addition, different sources define the term in a variety of ways, and many people use "risk," "threat," "vulnerability," and "loss" interchangeably. Regardless of what definitions one chooses, clarity requires that terms be used consistently. This paper, and the risk management program described, uses the following definitions, taken from Factor Analysis of Information Risk (FAIR):[1]

- **Risk:** probable frequency and magnitude of future loss
- **Asset:** something of value
- **Frequency:** how often a loss may occur within a given timeframe
- **Qualitative risk:** expressed in words, e.g. "High, Medium, Low"
- **Quantitative risk:** expressed in numbers, in this case $/timeframe
- **Threat:** something that may act to cause a loss
- **Threat event:** the thing the threat does that may cause a loss
- **Vulnerability:** a weakness that may allow a threat to cause a loss
- **Loss event:** the specific loss
- **Secondary loss event:** losses that may occur as a result of the primary loss, such as reputation loss or regulatory fines

Some risk management frameworks define risk as "uncertainty," including both positive and negative effects. This definition is not useful in the context of an information risk management program; there is no reasonable positive information security risk, protective botnets aside.[2] It also tends to confuse non-specialists, as the common understanding of risk is always negative.[3] It is, however, useful to talk about the uncertainty in the frequency or magnitude factors of risk. One purpose of a risk management program is to reduce that uncertainty; the theoretical, and impossible, end state is for all risks to be as well-understood as inventory shrinkage.[4] Reducing that potential loss is the other major goal, of course.

"Maturity," as used in this paper, means both the Capability Maturity Model type of maturity — from the process model developed by the Carnegie Mellon University Software Engineering Institute[5] — as well as more specific risk issues. Because risk management is a requirement, it is possible to enforce a high level of paperwork processing maturity without achieving effective risk management. **A mature risk management program includes two additional characteristics: the ability to discuss risk without redefining it or arguing regarding its utility every time, and to make those responsible for risks also accountable for them.**

The risk management options for organizations that lack this maturity are not good. Organizations that need risk management often hire consultants, but even high-level consultants fall into the same predictable failure patterns. Many immature risk programs default to a control deficiency audit and call that a risk assessment; while this is common enough and likely to pass an external audit, it does not actually find true risk and can exponentially increase busywork (multiply the number of controls assessed by the number of assets). Many organizations come to believe that the longer a risk assessment is, the more effective it is — and that may be the case if the measure of utility is passing an audit. For healthcare organizations, HealthIT.gov offers a Security Risk Assessment Tool,[6] which is relevant largely for reference and to set the bar for what auditors may be looking for. Many organizations, however, choose the easiest option: giving up.

The field needs a solution: a risk management program that passes audits, but is also genuinely useful to the business. This program should be inexpensive in both time and resources, and it should work at very small scale. Finally, the program needs to be able to grow with the organization and be able scale up — drastically — in the case of dramatic success, while continuing to effectively manage risk. This paper presents such a program.

The Basic Plan

A minimum viable risk management program requires the following steps:

1. Decide on scope
2. Inventory assets and owners
3. Sort the inventory by granularity
4. Perform Binary Risk Assessment (discussed in more detail below)
5. Asset owners decide treatment for low and medium risks
6. Senior leadership reviews all risks and decides on high
7. Document and review

Figure 1 on page 7 shows how the steps and documents interrelate.

Decide on scope

The first step is fairly simple, but extremely important: deciding on the scope of the risk management program. A minimum viable risk management program should cover the minimum scope required, rather than attempt to include all of the organization's assets, on the grounds that it is better to get something started than to try to do too much and founder. This scope depends upon the organizations obligations and objectives, but may include one or more of:

- Scope of upcoming audit(s)
- Assets subject to regulation, such as personally identifiable information and systems that touch that information
- Assets belonging to customers
- Trade secrets

Once the risk management process has successfully iterated one or more times, it is much easier to increase the scope.

Inventory assets and owners

Once the scope is decided, the assets within that scope — including data, physical assets, logical assets, and everything else — must be inventoried, with owners identified.

Admittedly, this is not a trivial task. It is, however, a necessary prerequisite to not only risk management, but almost all other security endeavors. It is difficult, if not impossible, to protect assets you do not know you have. It is important to consider all information assets, even those that do not have obvious monetary value, and even those you do not necessarily own, such as customer data.

This step is arguably one of the most difficult parts of any security program. Completing it will require leadership skills. However, identifying both assets and the owners of those assets will serve a variety of organizational objectives, in the risk management program and beyond.

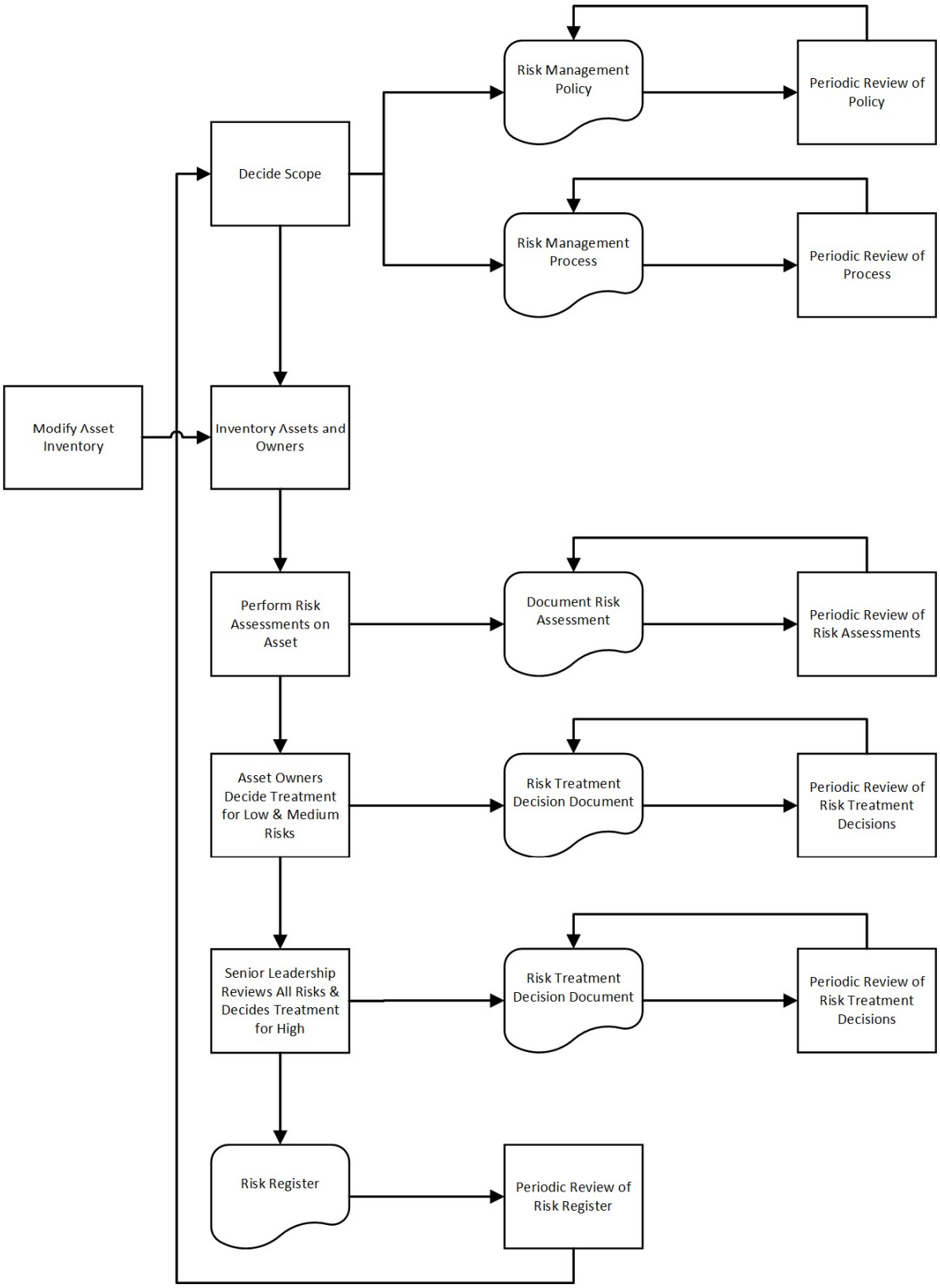

Figure 1. The Minimum Viable Information Risk Management Program

Sort the inventory by granularity

Once the assets are identified, they must be sorted. This step helps manage the varying scale of assets — many programs try to compare risks to data centers to single records. While some risk management methodologies account for this issue, the minimal set provided here does not.

Programs that do account for asset types often involves sorting assets by confidentiality, integrity, and availability requirements; some sort of sensitivity; or assurance levels. These attributes can become complex and difficult to manage. Another common method is to sort by presumed impact or business continuity criticality, which has two issues. First, you must identify your criticalities, by business impact analyses or other means, which is a non-trivial issue in itself. Second, this results in sorting assets by one of the factors of risk — impact — which leads to recursive definitions and confusion. In addition, both types of attributes can change rapidly in today's information processing environments.

The Harmonized Threat and Risk Assessment Methodology by the Royal Canadian Mounted Police[7] includes a straightforward and comprehensive sort of asset types by granularity in its Appendix B (along with more complex valuations not used here). An example is shown in Table 1. Using this method to sort assets has proven to be a relatively simple, stable, and easily manageable solution. While asset granularity can also change, those changes are less likely to go unnoticed — if nothing else, a historical view of invoices for cloud services may indicate changes in scale.

Asset Classes	Categories	Groups	Subgroups	Individual Components
Tangible assets	Data Hardware Software Facilities	Personal data Network components Computers Operating systems Buildings	Client data Firewalls Tablets Windows 10 Data centers	Credit record iOS tablets Release/ patch Specific building
People	Employees Contractors	Senior leadership Program staff	Managers Developers	Employee Contractor
Intangible assets	Internal External	Employee morale Public confidence	Department morale	
Services	Processes	System engineering processes	SDL	Detailed design

Table 1. Example of assets sorted according to the Harmonized Threat and Risk Assessment Methodology Appendix B.

Perform Binary Risk Assessment

Binary Risk Assessment (Binary) is a lightweight risk assessment methodology developed by Ben Sapiro.[8] It is Creative Commons licensed, free for commercial use, extremely quick, transparent, and compatible with other risk assessment methodologies. Almost no training is needed to enable both information security personnel and technical staff to perform assessments.

It is beyond the scope of this paper to reproduce the existing information on performing Binary. The Work Card[9] provides a compact explanation, as do the presentation[10] and whitepaper[11]. An

assessment involves answering the following ten questions, and then mapping the answers to a risk matrix:

1. Can the attack be completed with common skills?
2. Can the attack be completed without significant resources?
3. Is the asset undefended?
4. Are there known weaknesses in the current defenses?
5. Is the vulnerability in the asset always present?
6. Can the attack be performed without meeting preconditions?
7. Will there be consequences from internal sources?
8. Will there be consequences from external sources?
9. Does the asset have or create significant business value?
10. Will the repair or replacement costs be significant?

These questions are not always easily answered, but they do enable clear and productive discussions of the actual issues. The outcome is a High, Medium, or Low risk ranking.

While the website and whitepaper thoroughly document using Binary as an assessment tool, there is little guidance on using Binary as part of a risk management program. Starting at the Subgroup asset level (as defined in Table 1), select an asset, identify one or more probable scenarios (threat events that could affect that asset), and perform a Binary assessment for each scenario. Performing multiple assessments per asset is expected; because each assessment takes 5-10 minutes, it is feasible. This gives staff practice performing risk assessments, identifying sources of risk, and discussing differences. This practice allows the organization to train itself in risk assessment.

Identifying appropriate scenarios for a Binary Risk Assessment can be confusing at first. It is important to understand that Binary is narrowly scoped: a phishing scenario would be distinct, and require separate assessment from, a ransomware scenario. Many practitioners are accustomed to control-deficit questionnaires regarding each asset that are intended to cover a multitude of potential scenarios, and this narrow scoping requires some adjustment. Consider multiple assessments when:

- The threats do not have the same objectives (criminal organizations vs hacktivists)
- The threats do not have the same capabilities (script kiddies vs nation states)
- The threat events are different (phishing vs ransomware)

Finally, because risk is defined as the *probable* frequency and magnitude of future loss, only probable scenarios need be assessed. Movie-plot threat scenarios are not in scope.

Asset owners decide treatment for low & medium risks

The most difficult part of any risk management program is requiring asset owners to make risk decisions. There are several reasons for this. The obvious reason is that asset owners often do not want to be accountable if they don't have to be. The less obvious reason is that the information security and risk management functions frequently do not allow the asset owners to be responsible for the decision because we believe that the asset owner is making the wrong decision. The result is that the asset owner still controls the asset and how the risk is treated, if at all, but need not take

ownership of the decision. As information security professionals, we refuse to relinquish control, and then are surprised when we are held responsible.

If asset owners are to be responsible for risk decisions, they must have the latitude to make decisions we disagree with. The purpose of risk assessment, in the context of this risk management program, is to identify the relevant issues, talk about them productively, and provide subject matter expertise — not to make others agree we are right or do what we want. We must persuade, not attempt to coerce.

There are four ways to treat risk:

- Avoid (for example, not saving personal data in the first place)
- Mitigate (for example, adding controls such as log reviews or two-factor authentication)
- Transfer (for example, outsourcing payments or purchasing insurance)
- Accept (have someone at the right level agree that the organization will cover losses)

Determining the correct level to sign off on a risk is not easy. It can be helpful to think of this in terms of signing authority — one person may be able to sign off on $200, while another can sign off on $2 million. This is related to "risk appetite," or the level of loss exposure the organization views as acceptable. Formal risk management programs often require the organization to determine this in advance.[12] However, young and immature organizations do not yet have a basis for understanding what risk appetite and loss exposure mean to them. Attempting to define these before having a clear idea of the current risk frequently results in meetings spent arguing over abstractions and leaders becoming bored and irritated with the risk management process before it is even started. Any decision made will change as the organization learns more about its own risks.

For this reason, it's best for young and immature organizations to draw a line and adjust it as needed. One potential scheme (used here as an example, rather than a definitive requirement) is that asset owners decide treatment of low and medium risks to their assets, and senior leaders determine how to treat high risks.

Senior leadership reviews all risks & decides on high

Once a sufficient number of assets have been assessed and low and medium risk treatments decided, senior leaders should be engaged. They should meet with the risk management team to review the low and medium risk decisions, in order to know the context for their organization and potentially provide feedback regarding decision quality. Once the senior leaders understand the context, they make risk treatment decisions for all high risks.

Again, it is important that they have the latitude to make those decisions. Senior leadership is likely to be even less receptive to pressure than asset owners; making risk-based decisions is quite literally their job description. The role of the information security and risk management functions remains to identify the relevant issues, talk about them productively, and provide subject matter expertise — not attempt to coerce decisions we agree with.

Note that any feedback regarding decision quality should be given with care; do not discourage asset owners from being accountable for risk treatments. In particular, the information security or risk management functions should not use the senior leadership review to punish asset owners for low

and medium risk treatment decisions we merely disagree with. In most cases, if the risk were that important, it would have been a high risk.

One thing to keep in mind during this process is that an asset with more high risks is not necessarily a riskier asset. The number of risks and their level is a function of the imagination and thoroughness of the assessors, not objective reality. Risk aggregation is only possible in very mature risk management programs.

Document and review

A compliant risk management program will also require documentation and review, discussed below.

Strengths and weaknesses of Binary Risk Assessment

The risk management program outlined above is not perfect, and nor is it intended to be. Its primary weakness is the use of Binary, which is not a robust risk assessment methodology. Astute readers will have noticed that the Binary assessment does not actually meet the definition of risk used: "probable frequency and magnitude of future loss." Its questions focus on technology, not people or processes, and can be difficult to answer for non-malicious threats like user error or power outages. Binary also does not account well for secondary losses, which do not always follow the primary risk, but when they do can be disproportionately large. Breach notifications, fines, and reputation loss can far outstrip the immediate costs of a compromise. Finally, Binary is ambiguous regarding low frequency/high impact risks, which are common in information security.[13,14]

The High-Medium-Low risk rankings, while common to most risk assessment methodologies, are also problematic[15]. Risk matrices, equally common, have issues as well.[16] And, as noted, risk aggregation is impossible below a certain level of maturity.

However, the perfect must not be allowed to be the enemy of the good enough. The program outlined above is doable, even for very small and very immature organizations, most of which cannot begin to approach more established risk management practices. Binary allows an organization to teach itself how to think more maturely about risk.

Binary has an extraordinarily high return on investment compared to other assessment methodologies. The uncertainty reduction per minute of Binary exceeds everything else — probably by orders of magnitude. It does not require formal training: that alone democratizes the entire process. By giving untrained staff a structured way to talk about risk, it allows staff to train themselves to discuss risks effectively. The "culture of risk management" discussed in so many management journals actually becomes possible. In addition, smaller and less mature organizations are not able to tolerate much ramp-up time for a risk management program. Other methodologies may or may not provide more information in their assessments and more rigor in their practices, but they do so requiring a major investment in training, staff time, and processing.

Scaling the Program

At some point, leadership may begin asking more questions about risks identified and potential losses. This is the point where the program must scale up to meet the needs of the growing organization.

Factor Analysis of Information Risk (FAIR)[1] is a robust risk management and risk assessment methodology, developed by Jack Jones and adopted by the Open Group as its standard for risk management.[17] FAIR is free to read and has a sliding scale for commercial use. The training is relatively inexpensive.[18] FAIR can provide qualitative or quantitative analyses and does not require any vendor tools, although a platform enabling risk aggregation does exist.[19] A single assessment takes an experienced analyst approximately two hours — not as little as a Binary assessment, but still far less than many other methodologies.

Most importantly, FAIR uses the same narrowly-scoped scenarios that Binary does, enabling FAIR as a drop-in replacement for assets where more information is needed — and only those assets. This means that **the amount of work is driven by the value of the work**: the program can still be conducted using Binary, with FAIR assessments only completed when more information is desired. Performing Binary first requires a minimal amount of time and helps ensure that the scenarios are correctly scoped.

Qualitative FAIR assessments require only pen and paper; quantitative assessments use Monte Carlo techniques available in Excel, R, Python, or the RiskLens platform.[19] Everything needed to perform the assessment is documented in the Open FAIR Body of Knowledge[17] or the companion textbook.[20]

FAIR supports the highest levels of risk management complexity and maturity. FAIR risk management programs can be fully quantitative and effectively aggregate that quantitative risk to show loss exposure for the whole organization. However, if an organization does not need that level of rigor, it's not required: the basic program outlined above, using Binary with FAIR occasionally added for clarification, is sufficient for compliance, effective at providing business value, and sustainable over the long term.

Because there is so much information available on FAIR, training may not be necessary. However, because it is so very different from common risk management approaches a practitioner may have learned elsewhere, the training can be useful to clarify understanding and correct misconceptions.

Document and Review

Audits require artifacts of compliance, and the risk management process is no different from any other auditable process. The Minimum Viable Risk Management Program does not require expensive Governance, Risk, Compliance (GRC) tools, though it may make use of them. The program does require a system of record, an office suite, and (optionally) a workflow tool, all of which are available to even the smallest organizations.

A minimum document set for auditability is as follows:

- Risk management policy
- Risk management process
- Risk assessment templates and completed assessments
- Risk treatment decision templates and completed decision documents
- Risk register
- Meeting minutes

It is expected that an organization will adjust this to fit within their own document schema.

Risk management policy

A risk management policy provides the framework for and documents the scope of the risk management program. The policy should include the purpose of the program, its scope, the cadence of assessments (which may be as vague as "regularly or at major changes"), and a statement that the organization will treat risks to reduce loss exposure to an acceptable level. The policy should also document the principle that asset owners will sign off on risk treatments, not the information security or risk management function.

As part of the reviews discussed below, it is important to define how often risks and treatment decisions will be reviewed. The policy may also briefly cover documentation requirements that the organization imposes upon itself.

Risk management process

The risk management process supports the policy with details. It will identify the steps outlined above, with the addition of FAIR as an optional assessment methodology. Any additional steps defined in the policy, such as reviewing risks and treatment decisions, will also need a process documented here. Many organizations find a RACI matrix (Responsible, Accountable, Consulted, Informed) helpful. Example roles for this matrix would include:

- Risk management process owner — accountable for the risk management process
- Risk management process manager — responsible for the work
- Target asset owner — accountable for the asset and its risks
- Target process manager — responsible for the work
- Senior leader — accountable for the information risk of the entire organization

Risk assessment templates

A risk assessment template is simply a standardized way to document a risk assessment; it may be a document, a workflow ticket, or anything else that works for your organization. The completed risk assessment documents must be retained in the system of record.

Risk treatment decision templates

The risk treatment decision template is a way to document risk decisions. This may be part of the risk assessment template or separate. This form should include a description of the asset, the risk assessment, the risk rating, an executive summary of the chosen course of action and the business

justification, whatever discussion points or execution outline is valuable to the organization, and a signature (or equivalent) by the accountable asset owner or leader. Again, completed risk treatment decision documents are retained in the system of record.

Risk register

The risk register is a list of all risks and treatment decisions. Many audit regimes will ask for this document by name, so it is important to maintain one.

Depending on the audit framework being used, identifying a problem (such as a control deficiency, unaddressed risk, or other matter) in the risk register may mean that an audit finding is *not* issued, because the organization is aware of the problem and addressing it.

Meeting minutes

Finally, meeting minutes for the risk management program itself should be maintained, in order to have artifacts demonstrating that reviews occurred and decisions were made. The minutes should track the purpose of the meeting, date and time, attendees, items reviewed, and decisions made.

Review

Risk management is not just a process, but a program. There is no final state in which an organization's risk is completely understood and documented, unless the organization itself is dead. If nothing else, changes in an organization's information assets means that the process will need to be repeated to ensure that all assets have been assessed. New assets must have risk assessments performed. Documentation for retired assets needs to be updated to record the retirement of the associated risks. Changes to assets require new risk assessments to ensure that the risk rankings and treatment decisions are appropriate. There may also be program scope changes as more assets come under the purview of the risk management program, whether because of internal reasons, contracts, legislation, or other changes. The program must be able to adjust as the organization changes; for auditability, the program must include formal reviews to enable this.

The frequency and predictability of reviews depends on the organization's needs. The review requirements should be documented in the risk management policy, with details in the risk management process. Many frameworks require annual or more frequent reviews; some frameworks have no specific requirements. The following is a standard set of review activities for a risk management program, which can be adjusted as needed:

- Review the risk management policy
- Review the risk management process
- Review the risk assessments
- Review the risk treatment decisions
- Review the risk register

After review, appropriate updates should be made. Risk management documentation should be retained according to the organization's records policies and requirements.

Conclusion

Developing an information risk management program is a challenging task. Most current guidance is based on the practices of large, mature organizations that can support expensive processes and tools for the sake of audit requirements. However, there is a real need to bring solid risk management to smaller or less mature organizations that cannot afford the time or tooling required by the current guidance.

The measure of a risk management program is not whether the program passes an audit. That may be necessary, but it is the lowest possible bar — and far too many risk management programs do no more than that. The measure of a risk management program is the business value it brings. Are the processes aligned with business needs? Are potential sources of loss identified? Are problems brought to the right level for decisions, and are those decisions executed? Do the results support business objectives?

The goal of this whitepaper is to present a true risk management program that can be effectively implemented by a small or immature organization and that will provide value right away. While the initial assessment methodology, Binary Risk Assessment, has weaknesses, it has proven a remarkable tool for generating productive conversations about risk and allowing an organization to raise its own maturity through practice.

References

[1] https://www.risklens.com/what-is-fair

[2] Kan, M. (2017). A vigilante hacker may have built a computer worm to protect smart devices. *PCWorld.* Retrieved from https://www.pcworld.com/article/3191063/security/a-vigilante-hacker-may-have-built-a-computer-worm-to-protect-the-iot.html.

[3] https://www.merriam-webster.com/dictionary/risk

[4] https://en.wikipedia.org/wiki/Shrinkage_(accounting)

[5] http://cmmiinstitute.com/

[6] https://www.healthit.gov/providers-professionals/security-risk-assessment-tool

[7] Royal Canadian Mounted Police. (2007). Harmonized threat and risk assessment (TRA) methodology. ppB5-B6, B21-B28. Retrieved from https://www.cse-cst.gc.ca/en/system/files/pdf_documents/tra-emr-1-e.pdf

[8] https://binary.protect.io

[9] https://binary.protect.io/workcard.pdf

[10] https://sector.ca/sessions/binary-risk-analysis/

[11] https://binary.protect.io/#literature

[12] http://www.cert.org/resilience/products-services/octave/

[13] https://binary.protect.io

[14] Hutton, A. (2011). Some thoughts on Binary Risk Assessment. *The New School of Information Security.* Retrieved from http://newschoolsecurity.com/2011/10/some-thoughts-on-binary-risk-analysis/

[15] Hubbard, D. W. (2009). *The failure of risk management: why it's broken and how to fix it.* Hoboken, NJ: J. Wiley & Sons.

[16] Cox, L. A. Jr. (2008). What's wrong with risk matrices? *Risk Analysis,* 28(2), 497—512. doi:10.1111/j.1539-6924.2008.01030.x

[17] http://www.opengroup.org/subjectareas/security/risk

[18] https://www.risklens.com/fair-training-and-certification

[19] https://www.risklens.com/platform

[20] Freund, J. & Jones, J. (2015). *Measuring and managing information risk: a FAIR approach.* Oxford, UK: Butterworth-Heinemann.